



中国科学院大学

University of Chinese Academy of Sciences

研究生学位论文开题报告

报告题目 基于智能体的漏洞挖掘与修复技术研究

学生姓名 张小北 学号 202518018629028

指导教师 侯锐 职称 研究员

学位类别 工学博士

学科专业 计算机系统结构

研究方向 漏洞挖掘与修复

培养单位 中国科学院信息工程研究所

填表日期 2026 年 09 月

中国科学院大学制

报告提纲

一 选题的背景及意义	1
1.1 选题背景	1
1.2 选题意义	3
二 国内外本学科领域的发展现状与趋势	4
2.1 基于智能体的语义漏洞挖掘	4
2.2 基于智能体的漏洞自动修复	8
2.3 基于智能体的漏洞修复验证	10
三 课题主要研究内容与预期目标	16
3.1 研究思路	16
3.2 研究内容一：基于智能体的语义漏洞挖掘方法	19
3.3 研究内容二：基于智能体的漏洞自动修复方法	20
3.4 研究内容三：基于智能体的漏洞修复验证方法	20
3.5 预期目标与创新点	21
四 拟采用的研究方法、技术路线、实验方案及其可行性分析 ..	22
4.1 基于智能体的语义漏洞挖掘方法	22
4.2 基于智能体的漏洞自动修复方法	23
4.3 基于智能体的漏洞修复验证方法	25
4.4 实验方案设计	27
五 已有科研基础与所需的科研条件	29
5.1 已有科研基础	29
5.2 所需科研条件	29
六 研究工作计划与进度安排	29

一 选题的背景及意义

1.1 选题背景

1.1.1 漏洞攻防格局正在发生深刻变化

随着软件规模持续增长与软件供应链日益复杂，安全漏洞的数量、影响面与利用速度都在快速上升。一方面，国家级漏洞库中公开漏洞数量逐年攀升，攻击者利用公开漏洞信息实施“N-day 快速武器化”的窗口期不断缩短；另一方面，大量部署中的二进制组件缺乏透明、可验证的补丁状态，使下游用户与监管方难以判断“这个漏洞到底有没有被修复”。以 Log4j（CVE-2021-44228）为代表的事件表明：单一组件缺陷可以引发整个生态的修复验证难题 [1]。

与此同时，以大语言模型（LLM）为核心的**智能体（Agent）**技术正以前所未有的速度进入软件安全领域。与传统“静态规则 + 人工操作”的分析模式不同，智能体通过“模型推理 + 工具调用 + 迭代反馈”的闭环，能够自主完成代码阅读、二进制分析、测试用例生成、补丁合成等过去高度依赖专家经验的任务。Google Project Zero 与 DeepMind 的 Big Sleep 项目首次展示了 AI 智能体在真实开源项目中发现未知内存安全漏洞的能力 [2]；DARPA AIxCC 大赛则系统验证了智能体在“自动发现—自动修补—自动验证”全链路中的可行性 [3]。**智能体正从“辅助工具”演变为漏洞攻防闭环中的核心行动者。**

1.1.2 漏洞攻防闭环中的三个关键环节

一个完整的漏洞攻防闭环，可以抽象为三个相互衔接的核心环节：

1. **漏洞挖掘（Discovery）**：在目标软件中发现未知漏洞，回答“哪里可能有洞”。
2. **漏洞修复（Automated Vulnerability Repair, AVR）**：针对已确认存在的漏洞，自动定位并合成补丁，回答“怎么把洞补上”。
3. **漏洞修复验证（Repair Verification）**：判定修复是否真正消除漏洞根因、目标程序是否实际包含修复，回答“洞补上了没有、补得对不对”。

这三个环节覆盖了漏洞从“未知 → 已知 → 修复”的完整生命周期，彼此共享大量基础能力：对漏洞语义的理解、对补丁意图的建模、对二进制与源码之间

语义鸿沟的桥接、对修复正确性的判定。**然而，现有研究大多将三者割裂对待**，分别由不同团队、不同工具链、不同基准独立推进，导致漏洞语义、补丁语义、修复语义在各自环节中被重复建模，既浪费资源，也阻碍了跨环节能力的复用。

1.1.3 智能体带来的新机遇与新问题

智能体技术的引入，为统一上述三个环节提供了可能：

- **能力侧**：前沿编码智能体已能熟练调用 binutils、Ghidra、gdb 等二进制与源码分析工具，完成多步推理与决策。
- **成本侧**：token 成本与推理延迟的持续下降，使”在真实仓库级代码库上大规模运行智能体”从理想变为可行。
- **生态侧**：SWE-bench [4]、CVE-Bench [5]、AIxCC [3] 等评测基准的成熟，为系统化比较不同智能体安全能力提供了基础设施。

但与此同时，三个关键环节在智能体视角下仍各自存在未被充分回答的核心问题：

- 在漏洞挖掘上，传统 fuzzing 与符号执行在语义/逻辑漏洞（如认证绕过、状态机错误、配置驱动缺陷）上进展缓慢，**核心难点是”自因变量”——那些不受外部输入控制、由内部状态/配置/时序决定的变量——导致现有输入驱动方法在错误维度上爆炸。**
- 在漏洞修复上，智能体已能生成”看起来合理”的补丁，但”**补丁是否真正消除了漏洞根因**”这一判定问题（即 PPT 在修复场景下的对偶问题）仍缺乏可靠机制，导致现有基准上”补丁过拟合 PoC、回归失败、绕过检查”等问题频发 [6]。
- 在漏洞修复验证上，智能体虽已展现出与专用系统相当甚至更优的补丁存在性测试（PPT）性能 [7]，但**补丁定位（patch localization）**仍是主要瓶颈，且对”**演化补丁（patch evolution）**”的鲁棒性尚未解决——这部分能力本质上是漏洞语义理解问题。

由此可见，三个环节在智能体范式下并非彼此孤立，而是被一条隐含的主线紧密连接：**对漏洞—补丁—修复三者语义的统一建模与跨环节复用**。抓住这条主线，就有可能突破现有“单点智能体应用”的局限，构建面向完整攻防闭环的智能体安全分析体系。

1.1.4 选题的提出

基于上述观察，本文提出“**基于智能体的漏洞挖掘与修复**”这一研究课题，以“漏洞语义—补丁语义—修复语义”的统一建模为核心，系统研究智能体在语义漏洞挖掘、漏洞自动修复、漏洞修复验证三个关键环节中的能力边界、瓶颈机理与增强方法，并探索三个环节之间的能力迁移与反馈闭环。

1.2 选题意义

1.2.1 理论意义

1. **推动“智能体 + 程序分析”交叉范式的形成**：现有智能体安全研究多停留在“把 LLM 当作更强的分类器/生成器”层面，缺乏对智能体推理过程与程序分析约束之间关系的理论刻画。本课题将探索智能体的“观察—推理—行动”循环与污点分析、符号执行、规约验证等传统程序分析技术的耦合机制，为构建新型混合分析范式提供理论支撑。
2. **建立漏洞语义跨环节统一表示**：针对漏洞挖掘、修复、修复验证三环节语义割裂的现状，本课题尝试建立以“漏洞触发条件—补丁干预点—修复不变式”为核心的统一表示，为后续跨任务迁移学习、多任务智能体训练提供概念框架。
3. **深化对“自因变量”与“演化补丁”两类共性瓶颈的理解**：前者是语义漏洞挖掘的核心障碍，后者是 PPT 与修复共同面对的难点。本课题将从智能体视角对二者进行系统建模，形成可被后续研究复用的分析框架。

1.2.2 实践意义

1. **提升语义漏洞挖掘的自动化水平**：相比内存破坏漏洞，语义/逻辑漏洞（认证绕过、状态机错误、配置驱动缺陷）长期缺乏高效自动化检测手段。基

于智能体的挖掘方法有望通过自然语言规约理解、内部状态推断与测试用例合成，显著扩展可检测漏洞类型。

2. **提高自动修复的可信度**：通过将 PPT 思想引入修复验证环节，本课题旨在构建”修复—验证”闭环，减少”补丁过拟合 PoC”、”修复引入回归”等问题，提升智能体生成补丁的真实可用率，为软件供应链的快速应急响应提供工具支撑。
3. **支撑大规模供应链安全审计与修复状态核查**：PPT 是软件物料清单(SBOM)与漏洞影响评估的关键技术，也是修复验证能力的直接应用。基于智能体的端到端 PPT 可显著降低对符号表与人工目标函数定位的依赖，提升对剥离二进制与真实发行版包的分析能力，对关键基础设施软件资产盘点与修复状态核查具有直接价值。
4. **服务国家网络空间安全战略**：漏洞攻防能力是国家网络空间安全的核心竞争力之一。本课题围绕智能体这一新兴技术形态，系统研究其在漏洞攻防关键环节中的应用边界与增强路径，可为我国在下一代自动化攻防体系建设中抢占先机提供理论与技术储备。

二 国内外本学科领域的发展现状与趋势

本章围绕课题的三个研究点，分别梳理相关领域的研究背景、研究现状与趋势、以及尚存的关键挑战。其中，2.1 节对应语义漏洞挖掘研究点，2.2 节与 2.3 节分别对应拟开展的漏洞自动修复与漏洞修复验证研究。

2.1 基于智能体的语义漏洞挖掘

2.1.1 研究背景

漏洞挖掘旨在从目标软件中自动发现未知缺陷。经过数十年发展，以模糊测试 (Fuzzing)、符号执行 (Symbolic Execution)、污点分析 (Taint Analysis) 为代表的技术已在内存破坏类漏洞 (缓冲区溢出、释放后使用等) 上取得显著成功。然而，在语义/逻辑漏洞 (semantic / logic vulnerability) 方面，自动化挖掘能力仍然薄弱。

语义漏洞指程序在内存安全层面”合法”、但在设计意图或业务逻辑层面”错误”的缺陷，其典型类别包括：认证与授权绕过、状态机错误、配置驱动缺陷、第三方组件使用违规、跨组件逻辑错误等。与内存破坏漏洞不同，语义漏洞**不产生崩溃信号**，无法被 AddressSanitizer 等通用 oracle 直接捕获；其判定往往需要人工或半自动构造的策略/规约（policy/specification），这是语义漏洞挖掘区别于内存破坏挖掘的根本难点。

在 IoT 与嵌入式固件场景下，该问题尤为突出。固件通常包含大量由**内部状态、外设寄存器、NVRAM 配置、时序事件**共同决定的程序路径，这些路径对传统的输入驱动 fuzzing 而言几乎不可达。我们将这类”不受外部输入直接控制、由系统内部状态/配置/时序决定的变量”统称为**自因变量（Self-Caused Variables）**。自因变量普遍存在于认证逻辑、状态机转移、外设交互与配置处理中，是语义漏洞挖掘的核心障碍。

与此同时，大语言模型与智能体展现出前所未有的自然语言规约理解、跨抽象层推理与代码合成能力，为突破语义漏洞挖掘瓶颈提供了新的可能。智能体可以阅读协议 RFC、数据手册、配置说明等自然语言文档，自动提取安全不变量作为 oracle；可以在 fuzzing 循环中观察覆盖率停滞，主动推断需要翻转哪个内部状态变量，并合成对应的环境事件序列；还可以跨驱动层、RTOS 任务、应用层进行语义推理，识别跨层逻辑错误。

2.1.2 研究现状与趋势

（一）语义漏洞检测的传统方法 围绕语义漏洞检测，已有研究沿多条技术路线展开：

- **静态符号执行与模型检验**：Firmalice [8] 以”认证绕过”为唯一语义，结合特权模型进行符号执行，是该方向的奠基性工作；FIE [9] 面向 MSP430 固件进行全系统符号执行。此类方法受限于路径爆炸与环境建模难度，难以扩展到大型固件。
- **静态污点与数据流分析**：KARONTE [10] 通过跨二进制污点分析检测固件多进程通信中的逻辑缺陷；Operation Mango [11]、FIRE [12]、Octopus-Taint [13]、UVScan [14] 等工作进一步提升了可扩展性与检测精度；LATTE [15] 首次将 LLM 引入二进制污点分析，显著降低了规则定制成本。

- **固件重托管与覆盖率 Fuzzing**: FIRM-AFL [16]、P2IM [17]、Laelaps [18]、Fuzzware [19]、Ember-IO [20] 等工作通过外设建模与精确 MMIO 处理, 显著提升了固件 fuzzing 的覆盖率; Firmvenom [21] 引入外设语义感知 fuzzing, 进一步提升效率。
- **状态感知 Fuzzing**: AFLNet [22] 以协议状态机引导 fuzzing; StateAFL [23] 通过内存快照推断协议状态; SyzTrust [24] 面向可信执行环境, 明确提出”隐藏状态变量缺乏语义反馈”这一与自因变量高度对应的概念, 并通过状态感知 fuzzing 缓解深状态不可达问题。
- **配置驱动 Fuzzing**: CONFU [25] 等工作将配置文件直接作为 fuzz 输入, 绕开”配置变量在运行期不变”带来的自因性。

(二) **自因变量的建模与求解** 针对自因变量带来的挑战, 已有研究从不同角度提出了建模与求解思路, 如表 1 所示。总体上, SOTA 已从不把自因变量当作噪声, 而是将其**显式对象化**——或提升为 fuzzer 一等输入, 或通过符号/学习方法恢复其生成模型。但尚缺乏**统一抽象**来整合 **state-driven / config-driven / timing-driven / peripheral-driven** 等不同形态。

表 1 自因变量建模的代表性方法路线

方法路线	代表工作	核心思想
外设状态机学习	P2IM, Laelaps, Fuzzware, Firmvenom	将 MMIO 建模为状态机, 符号执行 + 自动机学习推断状态转移
运行时状态推断	StateAFL, SyzTrust	内存快照聚类推断隐藏状态, 将状态作为 fuzzer 一等公民
配置显式化	CONFU	将配置变量作为独立输入维度
反向数据流切片	KARONTE, Operation Mango	从 sink 反向切片, 识别不受 source 控制的变量并单独求解
混合执行	Laelaps, FirmHybridFuzz	输入不可解时切换符号执行, 将内部状态变量显式符号化

(三) **智能体在漏洞挖掘中的初步探索** 2024 年以来, 智能体在漏洞挖掘中的应用开始爆发: FirmAgent [26] 将 fuzzing 与 LLM 智能体结合, 由 fuzzing 提供污

点源，LLM 智能体进行上下文感知分析与 PoC 生成，在 14 个真实固件上发现 182 个漏洞，精度 91%，获得 17 个 CVE——这是目前该方向最强的公开结果；FirmPilot [27] 基于多智能体协作进行固件重托管，用 LLM 推断外设与环境语义；ChatAFL [28] 利用 LLM 提取协议语法、丰富种子、突破覆盖率平台；Big Sleep [2] 首次公开展示 AI 智能体在真实开源项目中发现未知内存安全漏洞；AIxCC [3] 系统验证了智能体在“发现—修补—验证”全链路中的能力。此外，BinReX [29] 提出的“语义检索 + 可验证推理”范式表明：为智能体提供检索增强的语义导航与机器可验证的证据链，相比单纯扩大模型规模或工具集更能提升二进制分析效果，这一范式对语义漏洞挖掘具有直接借鉴意义。

(四) 研究趋势 研究范式正从“LLM 作为分类器/生成器嵌入传统 pipeline”转向“智能体作为分析主体，自主规划分析路径”；研究对象从内存破坏漏洞扩展到语义/逻辑漏洞；系统架构从单智能体演进到规划—分析—验证分工的多智能体；评估对象从合成基准扩展到真实固件镜像与大型开源仓库。

2.1.3 研究挑战

1. **自因变量缺乏统一形式化**：state-driven、config-driven、timing-driven、peripheral-driven 等不同形态的自因变量在文献中各自为战，缺乏类似污点分析中 lattice 的统一抽象，导致方法难以泛化。
2. **语义 oracle 的自动构造**：逻辑漏洞的判定准则难以自动抽取，Firmallice 的认证绕过 oracle 使用十年仍是孤例。如何利用智能体从自然语言文档中自动提取安全不变量，是关键开放问题。
3. **覆盖率反馈对语义深度的“失明”**：coverage-guided 机制对“已覆盖代码内的逻辑错误”无感知，需要语义感知的反馈信号来替代或增强传统边覆盖。
4. **跨层语义鸿沟**：固件漏洞常跨越“驱动层 → RTOS 任务 → 应用层 → 云端/APP”，现有工具基本局限于单层，缺乏跨抽象层的语义整合能力。
5. **基准缺失**：缺乏公认的“语义漏洞 + 自因变量”基准，导致不同方法之间难以公平比较。

2.2 基于智能体的漏洞自动修复

2.2.1 研究背景

漏洞自动修复 (AVR) 旨在自动定位漏洞根因、合成补丁并验证其正确性，是连接漏洞发现与漏洞消除的关键环节。传统 AVR 研究在 C/C++ 与 Java 生态已积累了 GenProg [30]、SPR [31]、Prophet [32]、CapGen [33] 等一系列代表性工作，但长期受限于“修复空间搜索效率低、补丁正确性难以保证”两大瓶颈。

随着大语言模型与智能体的发展，AVR 正经历范式转变：从“基于规则与搜索的程序变换”转向“基于语义理解与多步推理的补丁合成”。然而，当前智能体修复仍面临一个根本性挑战：“补丁看起来合理”并不等于“漏洞被真正修复”。由于漏洞触发条件通常只是部分规约 (partial specification)，智能体容易生成过拟合于特定 PoC 的补丁——它们能让给定 PoC 不再触发，却未消除漏洞根因，甚至引入新的回归。

值得注意的是，这一问题与补丁存在性测试 (PPT) 在本质上是对偶的：PPT 回答“目标二进制是否包含修复”，AVR 验证回答“生成的补丁是否构成有效修复”。两者都需要对“漏洞语义”与“修复语义”进行深层建模。因此，本课题将 PPT 与 AVR 纳入统一框架，探索两者在智能体范式下的能力复用与相互增强。

2.2.2 研究现状与趋势

(一) 智能体漏洞修复的整体进展 以 AIxCC 决赛队伍为代表的系统展示了“漏洞发现 → 根因分析 → 补丁合成 → 验证”全链路自动化的可行性 [3]；SWE-bench [4]、CVE-Bench [5]、SEC-bench [34] 等基准的出现，使对智能体修复能力的系统评估成为可能；SWE-agent [35]、OpenHands [36]、RepairAgent [37] 等通用与专用修复智能体推动了该方向的普及。在 Rust 生态，RUSPATCH [38] 研究动态补丁，AkiraRust [39] 面向未定义行为的语义修复，但整体规模与场景仍有限。

(二) RRBench: 面向 Rust 真实漏洞的仓库级智能体修复基准 本课题组前期构建的 RRBench [6] 针对 Rust 生态缺乏大规模真实漏洞修复基准的问题，构建了包含 115 个案例、覆盖 95 个仓库的基准，其核心设计对本课题具有重要参考价值：

1. 两阶段评估设计：公开阶段向修复系统提供漏洞触发 PoC 与基础功能测试；

私有阶段使用对修复系统不可见的**安全性质检查**（security oracles）与**合法行为检查**，验证补丁是否真正恢复了应有的安全性质而非仅仅抑制 PoC。

2. **角色分离的自动建例智能体**：通过专门设计的智能体自动从真实仓库构建修复案例，保证基准的可扩展性。
3. **关键实证发现**：在五款代表性 LLM 修复智能体（OpenHands、SWE-agent、RepairAgent、RustAgent、RustForger）上的评估表明，824 个通过公开验证的最终提交中有 193 个（23.4%）未能通过私有安全性质检查；14 个案例未被任何系统正确修复；现有功能测试**高估了漏洞修复能力**，补丁验证必须显式建模安全性质。

这些发现揭示了智能体修复的核心瓶颈：**缺乏可靠的”修复正确性”判定机制**，导致”看似成功”的修复大量存在。RRBench 通过将 PPT 思想以”私有安全性质检查”的形式引入修复评估，为后续研究指明了方向。

（三）研究趋势 研究社区正从关注补丁生成能力，转向关注补丁正确性验证与修复质量评估；先进系统普遍采用”生成—编译—测试—反馈—再生成”的多轮闭环；利用漏洞类型相关的安全规约指导修复与验证成为提升补丁质量的关键路径；修复与漏洞挖掘、PPT 正从独立环节走向联动闭环。

2.2.3 研究挑战

1. **部分规约下的修复正确性判定**：漏洞触发条件通常只给出”什么是错的”，不给出”什么是对的”。如何在缺乏完整规约的情况下验证补丁，是 AVR 的根本挑战。
2. **过拟合与回归的系统性抑制**：现有智能体容易生成过拟合 PoC 的补丁，或在修复漏洞的同时破坏合法功能，需要在生成与验证两个环节同时引入约束 [6]。
3. **跨语言、跨生态的可扩展性**：现有基准与系统集中在 C/C++ 与 Java，对 Rust、Go、嵌入式 C 等生态的支持仍薄弱；不同语言的安全机制要求差异化的修复策略。

4. **修复与挖掘、PPT 的能力复用**：修复所需的”漏洞根因理解”与 PPT 所需的”补丁语义理解”高度同源，但现有研究尚未系统探索三者在统一智能体框架下的协同。

2.3 基于智能体的漏洞修复验证

2.3.1 研究背景

漏洞修复是软件安全保障的重要环节，其目标不仅是消除已知漏洞的触发条件，还需要在维持合法功能的前提下阻断危险行为。围绕这一目标，自动漏洞修复（Automated Vulnerability Repair, AVR）研究形成了漏洞分析、补丁生成与补丁验证三个主要环节，采用程序分析、约束求解、程序变换和学习等技术降低对人工修复的依赖 [40]。随着大语言模型的发展，修复过程进一步由单一补丁生成扩展为交互式任务执行。例如，PatchAgent 将缺陷定位、补丁生成与验证组织到同一智能体中，利用语言服务器和验证工具支持多轮修复 [41]。这些研究主要回答”如何产生有效修复”，但软件系统的实际安全状态还取决于修复能否被正确集成并传播至最终部署的程序。

从软件供应链的角度看，漏洞修复远超上游提交补丁这一局部开发活动，它贯穿上游项目、下游分支、发行版、设备厂商与最终用户，构成一个持续维护过程。Li 和 Paxson 对安全补丁的研究表明，补丁开发需要同时考虑修复完整性与功能回归，安全修复也可能仅涉及少量代码变化 [42]。针对修复在相关仓库之间的传播，Machiry 等提出 SPIDER，通过分析补丁的行为影响，识别适合向相关项目传播的修复 [43]。Zhang 等对 Android 内核补丁生态的研究进一步发现，修复在多层供应链中的传播可能存在较长延迟 [44]。因此，”补丁已经公开””下游已经合入”与”部署产物实际包含修复”是三个需要分别确认的状态。

版本信息和更新公告能够辅助判断修复状态，但不能在所有场景下替代程序级证据。一方面，下游维护者可能将安全修复回移植至较早版本，同时保留原有上游版本号。Red Hat 的安全回移植实践明确指出，仅依据上游版本号开展漏洞扫描可能产生误判 [45]。另一方面，闭源产品、固件和第三方二进制组件往往无法提供与部署产物完全对应的源码，导致使用者难以直接检查安全修复是否进入最终程序。由此，针对实际二进制开展独立的修复状态核查，成为连接补丁发布与安全维护的重要技术需求 [46]。

补丁存在性测试（Patch Presence Testing, PPT）正是针对这一需求提出的：给定已知漏洞的修复信息，以及补丁状态未知的目标程序，判断目标中是否包含对应修复的实现证据。不同方法使用的参考材料有所区别，包括源码补丁、修复前后源码、参考二进制或中间表示等 [46, 47]。PPT 与通用二进制相似性检测的区别在于，后者主要寻找功能或结构相近的代码，前者则需要在高度相似的两个实现之间识别安全相关差异。一个边界条件、错误分支或参数处理的变化，可能不足以明显改变函数整体相似度，却足以改变其漏洞状态 [47]。

需要区分的是，**PPT 核查”特定修复是否体现在目标程序中”，而补丁正确性验证考察”修复是否充分消除目标缺陷并维持合法行为”**。即使检测到参考修复已经存在，也不能据此证明参考补丁本身完整，更不能推导出目标程序不存在其他漏洞 [40, 42, 46]。因此，本节将 PPT 定位为漏洞修复生命周期中的部署侧验证环节，重点讨论其二进制证据提取、补丁语义匹配以及智能体化分析能力。

2.3.2 研究现状与趋势

（一）基于局部语法与结构差异的补丁存在性测试 基于语法与结构差异的方法通过比较修复前后的程序变化构造补丁特征，再在目标中搜索相应特征。与直接比较整个函数相比，这类方法将分析范围收缩到补丁影响区域，以减少无关代码变化对判定的干扰 [47, 48]。

Xu 等提出的 BinXray 采用两阶段匹配：先通过函数签名检索疑似目标函数，再通过修复前后函数之间的基本块映射提取补丁签名，利用长度敏感的相似性比较区分漏洞版本与修复版本 [47]。其重要特点是分析可以在二进制层面完成，不要求提供目标源码，并将函数检索与补丁匹配纳入同一流程。由此可见，传统方法已经开始关注目标定位，但函数级相似性只能提供候选范围，仍需进一步识别区分修复前后状态的补丁级证据。

PatchDiscovery 进一步关注补丁签名的选择性。该方法在规范化和简化的控制流图上匹配基本块，分别提取漏洞版本与修复版本的关键基本块，再在目标函数中比较其匹配情况 [48]。与保留较多路径信息的签名相比，关键基本块能够减少无关指令和版本变化引入的噪声。这一路线的共同优势是特征直观、匹配流程相对明确，适合进行快速筛查；但局部结构特征仍需要在参考程序与目标程序之间保持可对应性。编译优化、基本块重组以及补丁之外的结构变化，都会使”同

一修复”与”相似结构”之间的对应关系更加复杂 [47, 48]。

(二) 基于符号执行与中间表示的语义分析 为降低对指令形式的依赖，研究者开始利用符号执行和中间表示描述补丁引起的行为变化。Zhang 和 Qian 提出的 FIBER 结合源码变更分析与二进制符号执行，将选定的补丁位置转换为可匹配的二进制签名，并在匹配时结合局部控制流结构与语义公式 [46]。该方法通过结合结构约束与语义约束，增强签名对二进制表示差异的适应能力。FIBER 的实际评估使用带有符号信息的内核镜像；对于符号不可用的情形，论文讨论了接入相似性检索进行候选函数定位，但未在该工作中完成这一集成。

Jiang 等提出的 PDiff 面向经过厂商定制的下流内核，通过锚点基本块限定补丁影响路径，再利用路径约束、内存状态和函数调用等信息生成语义摘要，比较目标与修复前后参考版本的接近程度 [49]。该设计将比较对象从表面指令扩展为补丁相关路径上的行为，能够减轻定制代码的干扰。不过，其目标函数定位使用内核中的 KALLSYMS 信息，路径枚举也需要采取循环展开等近似策略，因此仍存在输入条件和分析范围上的边界。

Yang 等提出的 Robin 则通过符号执行寻找通向补丁区域的路径，构造能够区分修复前后行为的函数输入，并比较相同输入下的执行特征 [50]。它强调使用补丁引起的行为差异校验相似函数，而非仅依赖整体相似度。与此同时，函数级欠约束执行中得到的路径和输入，不必然对应完整程序中的真实可达执行，这也说明”行为特征相似””补丁存在”与”漏洞可实际触发”需要分别讨论。

PS³ 通过符号模拟提取寄存器写入、内存存储、条件与函数调用等语义签名，利用参考与目标之间的签名比较降低编译选项变化的影响 [51]。REACT 将源码编译得到的 LLVM IR 与目标二进制提升得到的 IR 纳入统一分析流程，通过语义特征提取、特征细化与排序，以及约束求解进行补丁判定 [52]。这些方法拓展了 PPT 的语义比较能力，但分析精度仍取决于符号模拟、二进制提升和特征抽象的准确性。IR 恢复误差与不完整的执行模型可能影响后续匹配，因此，即使采用约束求解，比较结论仍受所提取特征与建模条件的限制。

(三) 不同程序表示下的补丁检测与演化问题 除原生二进制外，Java 和 Android 字节码也形成了相应研究路线。BScout 直接检查 Java 可执行文件中的完整补丁，突破了仅依赖少量局部签名的传统做法 [53]；PPT4J 结合补丁的语义信息与

字节码特征，建立源码补丁行和二进制实现之间的对应关系 [54]；PHunter 面向 Android 应用中的混淆代码，通过由粗到细的定位与匹配提升补丁识别能力 [55]。这些方法表明，分析对象保留的信息、代码变换方式以及定位粒度，会直接影响技术设计。字节码场景的能力不能不加区分地推广到经过优化和符号剥离的 C/C++ 原生二进制。

另一个需要独立考察的问题是安全补丁演化。Xie 等系统研究了补丁代码在后续软件版本中的持续变化，以及这些变化对已知漏洞分析工具的影响 [56]。编译差异主要改变同一源码实现的机器级表达，而补丁演化可能直接改变修复实现，例如重组检查逻辑或调整相关代码。因此，能够抵抗编译选项变化，不等于能够识别经过长期重构的修复。由此可见，传统方法的关键问题不仅是生成更加稳定的签名，还包括厘清签名所代表的安全行为，以及该行为在不同实现中成立所需的条件。

(四) 基于大语言模型的补丁语义分析 大语言模型为连接高层修复信息与低层程序表示提供了新的技术途径。DeGPT 利用模型改善反编译结果的可理解性，LLM4Decompile 探索从二进制代码生成或改进类源码表示，ReSym 则结合模型与程序分析恢复剥离二进制中的变量和数据结构符号 [57–59]。这些工作提供的是程序理解的辅助能力，并不直接回答特定安全补丁是否存在；它们的价值在于为跨表示的语义定位与比较提供了基础。

Li 等提出的 Lares 是直接面向 PPT 的 LLM 方法。它从修复前后源码提取补丁相关切片，补充数据依赖、控制依赖和宏信息，再由 LLM 将切片映射到目标函数的反编译伪代码；随后利用 Z3 检查可提取公式的等价性，并在不能直接判定时使用 LLM 比较语义 [60]。这种设计消除了为提取参考特征而重新编译历史版本的要求，将模型用于跨表示定位，而非仅作为最终二分类器。

Lares 的适用边界同样重要：**其方法明确假设潜在漏洞函数已由外部二进制相似性方法识别，所解决的定位主要限于目标函数内部的代码切片定位，尚未覆盖从完整二进制独立完成全部检索步骤的场景。**其失败分析还指出，重复检查与细微修改可能干扰判断 [60]。因此，“能够处理剥离后二进制的伪代码”与“不依赖任何定位提示完成端到端分析”并非同一能力；局部公式匹配也不能替代完整安全语义验证。

Xu 等提出的 PPTSP 采用另一种混合设计：先对语义等价的指令序列进行规范化，再提取补丁影响的关键控制路径以减少无关代码干扰，最后在结构特征相近时引入 LLM 判断语义等价性 [61]。与 Lares 将模型用于源码—伪代码映射不同，PPTSP 主要将模型用于传统特征处理之后的语义判别。两者体现出互补的结合方式：模型可以辅助定位候选证据，也可以处理已有特征难以区分的情况，但不同使用位置带来的收益与风险需要分别评估。

(五) 从 LLM 增强流水线到交互式智能体分析 将 LLM 加入某个分析阶段，与由智能体组织完整分析过程仍存在区别。SWE-agent 的研究表明，专门设计的智能体—计算机接口能够支持模型自主浏览仓库、执行程序并根据反馈调整操作 [35]。结合这一交互范式，可以进一步探索由智能体围绕补丁假设主动选择二进制分析工具，在候选检索、局部检查与证据补充之间迭代，避免始终沿固定顺序运行预定义模块。不过，通用代码任务与 PPT 在分析对象和证据要求上存在差异，这种交互能力能否转化为可靠的端到端补丁检测，仍需要专门研究。

这一变化还意味着评价对象需要从单次模型输出扩展为完整分析系统。模型、工具接口、上下文组织、停止条件与重试机制都会影响执行过程；有关智能体评价的研究也指出，仅关注任务准确率而忽视资源使用和复现条件，可能对系统实用性产生误判 [35, 62]。对 PPT 而言，需要进一步回答：模型能否自行找到正确代码，工具返回的信息能否构成补丁证据，失败发生在哪个环节，以及正确结论需要付出多少分析成本。因而，现有研究呈现出的发展方向已超越简单地“以 LLM 替代传统程序分析”，更强调将程序分析提供的可检查证据与模型的语义推理、任务规划能力结合，并对整条流程进行验证。

围绕上述问题，本人前期已开展两项相互衔接的实证研究。其一，针对现有 PPT 研究评估数据集有限且不一致、失败根因缺乏系统理解的问题，构建了包含 561 个 CVE、覆盖 10 个广泛使用开源项目的高保真基准，对五款代表性工具进行系统评估，揭示了“高准确率、低决策成功率”的普遍现象，并将失败模式归纳为算法层局限与工程层缺陷两大类 [63]。其二，针对智能体能否胜任端到端 PPT 这一问题，系统评估了通用编码智能体在符号可见、剥离二进制、演化补丁与真实发行版包等场景下的能力边界，发现前沿智能体仅使用 binutils 即可达到与专用 SOTA 系统相当的性能，但补丁定位与演化补丁识别仍是主要瓶颈 [7]。这两

项工作作为研究内容三的提出提供了直接的实证基础。

2.3.3 研究挑战

(一) 缺少定位提示时，补丁语义与目标代码之间的可靠对应 现有方法在定位方面具有不同前提：FIBER 和 PDiff 的评估或实现利用目标符号信息，BinXray 包含函数级检索，Lares 则假设目标函数已由外部方法识别 [46, 47, 49, 60]。这些差异意味着，已知目标函数上的匹配效果不能直接代表完整二进制上的端到端效果。面向实际部署，分析不仅需要找到语义相关的函数，还必须确定具体检查作用于哪个对象、处于哪个程序位置，以及是否约束了对应危险操作。后续研究需要将函数检索、程序点定位与语义验证联系起来，并在候选存在歧义时继续收集证据，避免直接接受首个相似结果。

(二) 参考实现变化时，修复语义的保持与可观察性 语法签名、符号执行摘要和 IR 特征分别缓解了不同形式的程序差异，但它们仍基于一定的实现对应关系 [47–52]。补丁演化研究则表明，原始修复代码会在后续版本中持续变化 [56]。因此，需要进一步区分“原有补丁模式不再出现”与“修复效果不再存在”：前者可能只是实现调整，后者才涉及修复缺失。针对这一问题，应围绕检查对象、必要前提、错误传播和危险操作之间的关系组织验证，并按需扩展至调用上下文，避免仅停留在提高局部签名的匹配容忍度。同时，当给定分析范围内缺乏可区分证据时，应保留判断边界，不能以模型推测弥补不可观察信息。

(三) 模型推理与程序证据之间的一致性 Lares 和 PPTSP 将模型用于定位或语义判别，说明自然语言推理能够参与传统分析难以直接处理的环节 [60, 61]。但模型生成的解释、反编译输出以及求解器结论具有不同的证据性质：解释需要对应实际代码，伪代码依赖反编译恢复质量，求解结论则受公式建模范围约束 [52, 57, 59]。后续研究需要明确每个结论依赖哪些地址、语句、控制关系和数据关系，并针对竞争性解释寻找反证。还应区分未发现修复、漏洞相关功能不适用和分析未完成，避免将工具失败或检索无结果直接转换为漏洞状态判断。

(四) 不同研究条件下，能力与失败机制的可比较性 代表性 PPT 研究分别采用内核、通用 C/C++ 项目、Java 字节码或 Android 应用，并在参考材料、定位支

持与编译条件上具有差异 [46–55]。因此，论文中的单一准确率或 F1 值不能脱离实验设置进行直接排序。需要在统一条件下分别考察特征生成、目标定位、语义判定与完整流程，明确是否提供符号、候选函数和调试信息，并同时记录错误判定、无法判定、超时与工具异常。只有保留这些失败情形，才能进一步判断局限源于补丁语义不可区分、实现假设不满足，还是工程处理过程不完整，避免将所有失败混为模型或算法精度问题。

(五) 智能体分析效果、工具配置与成本之间的权衡 交互式分析扩大了系统可以探索的证据空间，也增加了工具调用、上下文维护和重复推理的成本。通用智能体研究已经揭示接口设计和资源评价的重要性 [35, 62]，但不能由此预设 PPT 中“更大模型”“更多工具”或“更长上下文”必然带来更好效果。需要针对漏洞元数据、模型配置、工具能力与任务预算开展受控比较，研究如何优先使用低成本线索缩小范围，再针对关键证据缺口调用复杂分析，并同时评价正确性、完成率、时延和资源消耗。

综上，现有研究已经从补丁局部差异匹配发展到符号语义分析，并开始引入 LLM 进行跨表示定位与语义判别。然而，面向实际部署产物的可靠 PPT，仍需要贯通补丁理解、无充分提示的目标定位、演化修复识别和证据约束下的结论生成。对这些环节进行统一评估与失败机理分析，并探索程序分析和智能体推理之间的有效分工，是本课题研究内容三的主要切入点。

三 课题主要研究内容与预期目标

3.1 研究思路

漏洞挖掘、漏洞自动修复与漏洞修复验证构成了漏洞攻防闭环的三个关键环节，三者共同依赖于对漏洞语义、补丁语义与修复语义的深层理解。然而，现有研究大多在“预定义规则 + 人工编排”的静态范式下分别推进三个环节，导致语义建模重复、能力难以复用、判定过度依赖专家经验。随着大语言模型与编码智能体的快速发展，一种以“模型推理 + 工具调用 + 迭代反馈”为核心的新型分析范式正在形成，为统一三个环节提供了契机。但与此同时，三个环节在智能体范式下仍各自面临深层语义推理瓶颈：在漏洞挖掘上，自因变量与语义 oracle 缺失制约着语义/逻辑漏洞的自动化发现；在漏洞修复上，部分规约下的修复正确

性判定导致”补丁过拟合 PoC”问题普遍存在；在漏洞修复验证上，补丁定位与演化补丁识别仍是主要失分点。本文旨在提出基于智能体的漏洞挖掘与修复技术，通过统一建模漏洞—补丁—修复语义，并构建三个环节之间的能力复用与反馈闭环，实现高效、可靠的漏洞攻防自动化。

本课题的总体研究框架如图 1 所示，自下而上分为数据与基准层、智能体基础设施层、方法层与应用层四个层次。三个研究内容在闭环中形成有机整体：研究内容一（语义漏洞挖掘）产出的漏洞根因与 PoC 为研究内容二（漏洞自动修复）提供语义先验；研究内容二生成的候选补丁交由研究内容三（漏洞修复验证）进行修复正确性判定；研究内容三在验证过程中积累的安全性质规约又反过来增强研究内容一的语义 oracle 构造能力。

应用层：漏洞攻防闭环

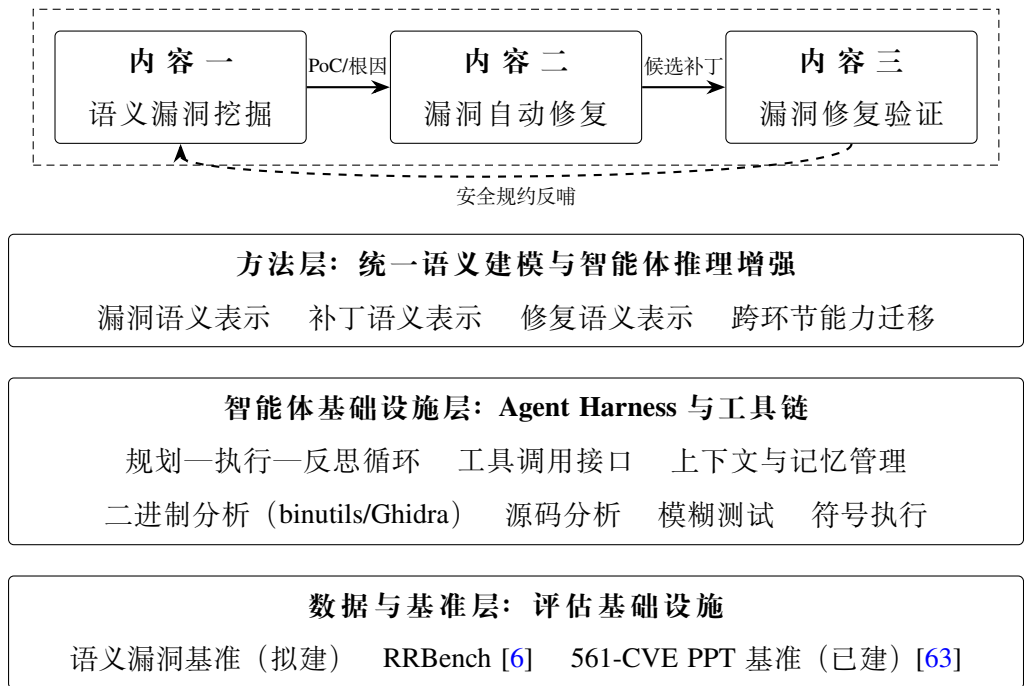


图 1 总体研究框架

针对基于智能体的语义漏洞挖掘，当前工作主要通过覆盖率引导的模糊测试与静态污点分析发现内存破坏类漏洞，存在对无崩溃信号的语义/逻辑漏洞检测能力不足的问题，因此面临自因变量难以统一建模、语义 oracle 难以自动构造的挑战。自因变量——那些不受外部输入直接控制、由内部状态、配置、时序与外设决定的变量——使传统输入驱动方法在错误的维度上搜索，而语义漏洞的判定又依赖人工构造的策略与规约。尽管已有工作在固件外设建模、协议状态

感知与智能体辅助分析上取得进展 [17, 19, 22, 26], 但尚缺乏将自因变量显式对象化、并自动从自然语言文档提取安全不变式的系统化方法。

针对基于智能体的漏洞自动修复, 当前工作主要通过”缺陷定位—补丁生成—测试验证”的单向流程合成补丁, 存在对补丁是否真正消除漏洞根因缺乏可靠判定的问题, 因此面临**部分规约下修复正确性难以验证、过拟合与回归难以系统抑制**的挑战。以 RRBench 为代表的大规模评估表明, 现有智能体生成的”公开合理”补丁中有相当比例在私有安全性质检查下失败, 且存在多个案例无法被任何系统正确修复 [6]。其根本原因在于修复环节缺乏对”修复意图”的语义判定能力, 而这一能力恰与补丁存在性测试中的”补丁语义判定”高度同源, 但现有研究尚未系统探索两者的对偶迁移。

针对基于智能体的漏洞修复验证, 当前工作主要通过预定义语法特征或语义签名判断目标程序是否包含特定修复, 存在对符号表与人工目标函数定位的强依赖、对演化补丁识别能力不足的问题, 因此面临**跨抽象层次补丁语义对齐困难、修复意图难以形式化**的挑战。虽然前沿编码智能体已在端到端补丁存在性测试 (Patch Presence Testing, PPT) 上展现出与专用系统相当的性能 [7], 但其失败高度集中于剥离二进制中的补丁定位与演化补丁识别两个环节, 且单次推理成本仍较高, 难以同时支撑大规模软件供应链审计与修复正确性判定两类需求。

针对上述三个方面的挑战, 本文计划如下开展研究工作:

针对**自因变量难以统一建模、语义 oracle 难以自动构造**的挑战, 本文提出**基于智能体的语义漏洞挖掘方法**, 通过构建统一的自因变量格以整合状态、配置、时序与外设等不同形态的内部变量, 并利用智能体从自然语言文档自动提取安全不变式作为运行时 oracle, 进而设计规划—执行—验证三智能体协同的模糊测试框架, 实现语义/逻辑漏洞的高效自动化挖掘。

针对**部分规约下修复正确性难以验证、过拟合与回归难以系统抑制**的挑战, 本文提出**基于智能体的漏洞自动修复方法**, 通过依托统一的漏洞语义五元组表示将漏洞报告与 PoC 转化为结构化根因语义, 利用智能体自动提取补丁必须满足的安全性质规约并引导多轮补丁生成, 合成高质量候选补丁, 为修复验证环节提供规约与判定依据。

针对**跨抽象层次补丁语义对齐困难、修复意图难以形式化**的挑战, 本文提出**基于智能体的漏洞修复验证方法**, 通过离线提取”触发条件—危险操作—干预点

“修复意图—上下文”的漏洞语义五元组，在线引导智能体进行粗细两阶段补丁定位与基于修复意图的语义等价判定，实现剥离二进制与演化补丁场景下高决策成功率、低推理成本的端到端修复状态验证，并将补丁语义判定能力对偶迁移至研究内容二的修复正确性验证。

3.2 研究内容一：基于智能体的语义漏洞挖掘方法

主要内容：语义/逻辑漏洞（如认证绕过、状态机错误、配置驱动缺陷）不产生崩溃信号，长期缺乏高效的自动化挖掘手段，是 IoT 与嵌入式固件安全中的突出短板。其核心难点在于：此类漏洞的触发路径通常由内部状态、配置、时序与外设响应等**自因变量**共同决定，传统输入驱动的模糊测试难以在错误的维度上有效探索；同时，语义漏洞的判定依赖人工构造的策略与规约，**oracle** 的缺失使自动化检测难以规模化。本研究内容旨在通过统一建模自因变量、自动构造语义 **oracle**、设计自因变量感知的智能体模糊测试，突破语义漏洞挖掘的自动化瓶颈，扩展可检测漏洞的类型与规模。

当前工作存在**自因变量难以统一建模、语义 oracle 难以自动构造**的挑战，因此，本文提出**自因变量感知的多智能体语义漏洞挖掘框架**。具体而言，首先综合静态分析与智能体推理，在固件二进制上识别各类自因变量，并统一表示为标注来源类型、取值空间与影响路径的自因变量格，使其成为模糊测试的一等探索维度；其次，利用智能体从协议 RFC、芯片数据手册与配置说明等自然语言文档中自动提取安全不变式，并编译为可执行的运行时监测点与断言，解决 **oracle** 自动构造难题；最后，设计规划—执行—验证三智能体协同的模糊测试架构，由规划智能体根据覆盖率与不变式反馈规划探索策略，执行智能体在生成输入的同时主动翻转目标自因变量（如注入中断、修改 NVRAM、模拟外设响应），验证智能体检查不变式违背并报告候选漏洞，并配套 PoC 生成与根因定位能力。

预期目标：构建基于智能体的语义漏洞挖掘系统，在真实 IoT 固件与合成基准上验证有效性，相比现有最优模糊测试方法在语义漏洞发现数量上提升 ≥ 5 倍，自因变量覆盖率 $\geq 70\%$ ，安全 **oracle** 自动构造准确率 $\geq 80\%$ ，在认证绕过、状态机错误与配置驱动缺陷三类典型语义漏洞上各发现若干真实漏洞并获得 CVE 编号，形成可复用的固件语义漏洞基准与工具原型。

3.3 研究内容二：基于智能体的漏洞自动修复方法

主要研究内容：漏洞自动修复是连接漏洞发现与漏洞消除的关键环节，其目标是自动定位漏洞根因、合成补丁并验证正确性。以 RRBench 为代表的大规模评估揭示了一个关键问题：现有智能体生成的“公开合理”补丁中，有相当比例（23.4%）在私有安全性质检查下失败，且存在多个案例无法被任何系统正确修复 [6]。其根本原因在于：修复环节缺乏对“修复意图”的语义判定能力，智能体容易生成仅抑制特定 PoC、却未消除漏洞根因的过拟合补丁。值得注意的是，这一问题与补丁存在性测试中的“补丁语义判定”在本质上是“对偶的”——前者回答“生成的补丁是否构成有效修复”，后者回答“目标二进制是否包含修复”——两者均需对漏洞语义与修复语义进行深层建模。本研究内容旨在构建规约引导的可信自动修复框架，生成高质量候选补丁，并与研究内容三的修复验证方法形成“生成—验证”协同。

当前工作存在**部分规约下修复正确性难以验证、过拟合与回归难以系统抑制**的挑战，因此，本文提出**规约引导的智能体漏洞修复框架**。具体而言，首先依托统一的漏洞语义五元组表示（与研究内容一、三共享），将漏洞报告与 PoC 转化为结构化的根因语义表示；其次，借鉴 RRBench 私有 Oracle 的设计思想但将其自动化，利用智能体基于漏洞语义与代码上下文自动提取补丁必须满足的安全性质集合，既指导补丁生成又作为最终验证依据；再次，修复智能体在根因语义与安全规约的双重引导下进行多轮补丁生成与迭代，通过编译、公开测试与静态检查反馈持续修正候选补丁；最后，候选补丁交由研究内容三的修复验证环节进行 PPT 式的修复正确性判定，二者构成“生成—验证”对偶闭环，系统性抑制过拟合补丁与合法功能回归，实现部分规约下可信的自动修复。

预期目标：构建基于智能体的漏洞自动修复系统，在 RRBench 基准上将正确修复率从当前最优 69.6% 提升至 $\geq 80\%$ ，私有验证拒绝率降低 $\geq 50\%$ ，在现有任何系统均无法正确修复的 14 个案例上成功修复 ≥ 4 个，形成可复用的安全规约自动提取工具链，并将方法论扩展至 C/C++ 等其他语言生态的修复基准。

3.4 研究内容三：基于智能体的漏洞修复验证方法

主要研究内容：补丁存在性测试（Patch Presence Testing, PPT）是连接漏洞披露与实际防护的关键环节，在软件供应链安全审计中具有不可替代的作用；同

时，修复验证也是漏洞自动修复闭环的收官环节——自动合成的补丁是否真正消除漏洞根因，最终需要同样的补丁语义判定能力来回答。本人前期实证研究表明，前沿编码智能体已在端到端补丁存在性测试上达到与专用 SOTA 系统相当的性能 [7]，但其失败高度集中于两个环节：剥离二进制中的补丁定位，以及对后续版本中演化补丁的识别。前者源于源码级补丁意图与二进制级指令序列之间存在跨抽象层次的语义鸿沟，后者源于现有方法过度依赖补丁的形式特征而非修复意图。本研究内容旨在通过引入统一的漏洞语义表示，增强智能体在两个瓶颈环节上的推理能力，推动端到端修复状态验证从“可用”走向“可信、可扩展”，并将补丁语义判定能力对偶迁移至自动修复的补丁正确性验证。

当前工作存在**跨抽象层次补丁语义对齐困难、修复意图难以形式化**的挑战，因此，本文提出**语义先验引导的智能体修复验证增强框架**。具体而言，离线阶段利用智能体从 CVE 描述、补丁 diff 与源码上下文中提取“触发条件—危险操作—干预点—修复意图—上下文”的漏洞语义五元组，作为统一语义先验；在线阶段采用“粗—细”两阶段补丁定位，先用启发式规则快速缩小候选函数集，再以五元组为约束引导智能体在反汇编切片中进行置信度排序；针对演化补丁，提出基于修复意图的语义等价判定方法，不再追求形式上的补丁匹配，而是验证目标二进制中的干预是否实现了与原始补丁相同的安全语义。该框架在保持推理成本可控的前提下，系统性提升补丁定位准确率与演化补丁识别能力。

预期目标：构建基于智能体的端到端漏洞修复验证系统，在 561-CVE 基准上实现 $DSR \geq 0.98$ ，在演化补丁子集上 DSR 提升 $\geq 15\%$ ，在 Ubuntu 真实发行版包上保持 $DSR \geq 0.95$ ，单例推理成本相比前沿配置增加不超过 10%，形成可支撑大规模软件供应链审计与修复正确性判定的工具原型。

3.5 预期目标与创新点

（待撰写：分点列出理论创新、方法创新与系统/工具成果，以及预期论文与专利产出。）

四 拟采用的研究方法、技术路线、实验方案及其可行性分析

4.1 基于智能体的语义漏洞挖掘方法

拟解决的关键问题：语义/逻辑漏洞（认证绕过、状态机错误、配置驱动缺陷）自动化挖掘的两大瓶颈——**自因变量难以统一建模与语义 oracle 难以自动构造**。自因变量——那些不受外部输入直接控制、由内部状态、配置、时序与外设决定的变量——在文献中以 state-driven、config-driven、timing-driven、peripheral-driven 等不同形态各自为战，缺乏统一抽象；同时，语义漏洞的判定依赖人工构造的策略与规约，Firmalice 的认证绕过 oracle 使用十年仍是孤例 [8]，oracle 的缺失使自动化检测难以规模化。

技术方案：针对上述问题，本文提出**自因变量感知的多智能体语义漏洞挖掘框架**，整体技术路线如图 2 所示，包含四个核心模块：

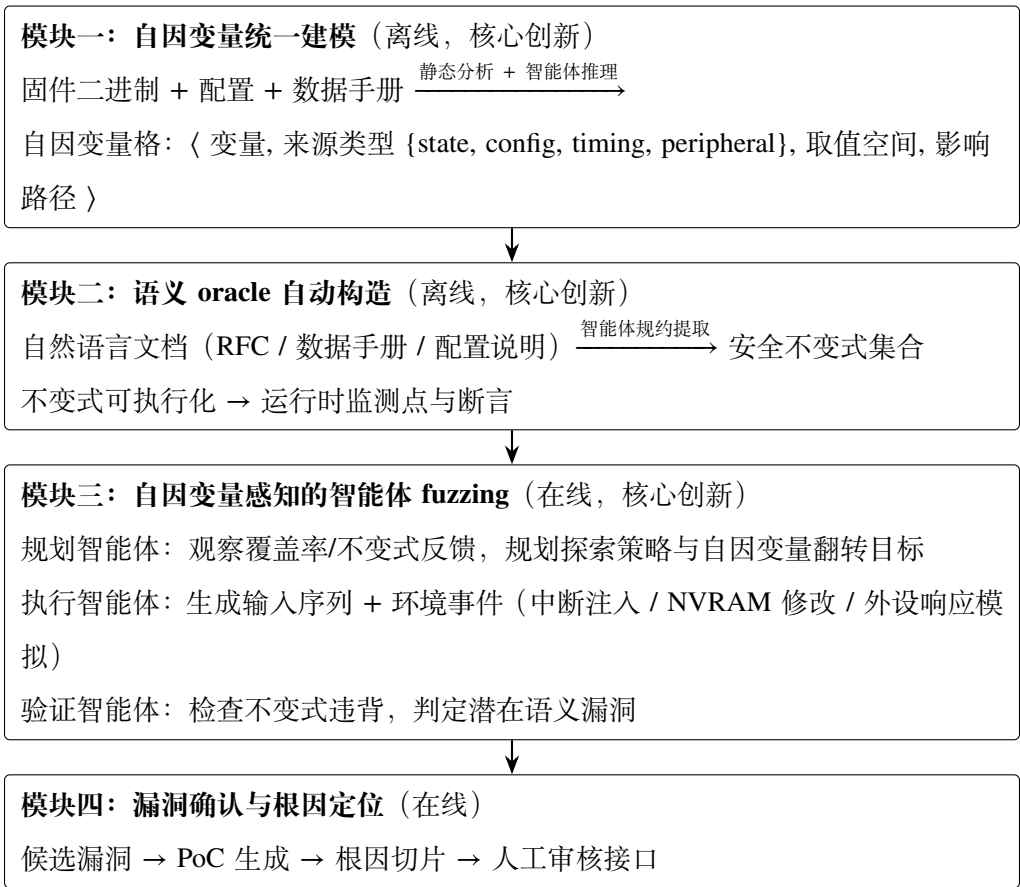


图 2 基于智能体的语义漏洞挖掘技术路线

- **模块一：自因变量统一建模。**综合静态分析与智能体推理，在固件二进制上识别各类自因变量，并统一表示为标注来源类型、取值空间与影响路径

的自因变量格，使后续 fuzzing 能够将自因变量作为一等探索维度。

- **模块二：语义 oracle 自动构造。**利用智能体从自然语言文档（协议 RFC、芯片数据手册、配置说明）中自动提取安全不变式，并将其编译为可执行的运行时监测点与断言，解决语义漏洞挖掘中”oracle 靠人工”的长期瓶颈。
- **模块三：自因变量感知的智能体 fuzzing。**采用规划—执行—验证三智能体协同架构：规划智能体根据覆盖率与不变式反馈规划探索策略；执行智能体在生成输入的同时，主动翻转目标自因变量；验证智能体检查不变式违背。该模块突破传统 fuzzing 仅在输入空间探索的局限。
- **模块四：漏洞确认与根因定位。**对验证智能体报告的候选漏洞，自动生成 PoC，通过动态切片定位根因，并提供人工审核接口。

可行性分析：（1）理论可行：自因变量概念已在 SyzTrust [24]、Fuzzware [19] 等工作中以不同形态出现，本方案是对这些分散实践的统一与提升；（2）技术可行：多智能体协同架构已在 FirmAgent [26] 中得到初步验证，LLM 的规约理解能力已在 ChatAFL [28] 等工作中展现，”语义检索 + 可验证推理”的 agentic 范式已在通用二进制分析任务上被证明有效 [29]；（3）工程可行：课题组在固件分析、智能体框架与 fuzzing 工具链上有完整积累，RRBench 的”角色分离智能体”设计模式可直接复用 [6]；（4）数据可行：可通过公开固件数据集与 FreeRTOS、Zephyr 等开源 IoT 项目获取评估对象，并可人工植入语义漏洞构建合成基准。

实验方案：基准包括 10–15 个含已知语义漏洞的真实 IoT 固件（含认证绕过、状态机错误等）与参考 LAVA-M 设计的 50+ 合成植入漏洞；对比方法包括 FIRM-AFL [16]、Fuzzware [19]、FirmAgent [26]、ChatAFL [28]、AFLNet [22]；评估指标包括语义漏洞发现数量、首次发现时间、假阳性率、自因变量覆盖率、oracle 自动构造准确率；消融实验分别验证自因变量建模、自动 oracle 与多智能体协同的独立贡献。预期语义漏洞发现数量相比最优基线提升 ≥ 5 倍，自因变量覆盖率 $\geq 70\%$ ，oracle 自动构造准确率 $\geq 80\%$ 。

4.2 基于智能体的漏洞自动修复方法

拟解决的关键问题：智能体漏洞自动修复的两大瓶颈——部分规约下修复正确性难以验证与过拟合与回归难以系统抑制。RRBench 大规模评估表明，现

有智能体生成的”公开合理”补丁中 23.4% 在私有安全性质检查下失败，且 14 个案例未被任何系统正确修复 [6]。其根本原因在于：修复环节缺乏对”修复意图”的语义判定能力，智能体容易生成仅抑制特定 PoC、却未消除漏洞根因的过拟合补丁，或在修复漏洞的同时破坏合法功能。

技术方案：针对上述问题，本文提出**修复—验证对偶的智能体漏洞修复框架**，核心思想是将 PPT 的”补丁语义判定”能力对偶迁移为”修复正确性验证”，整体技术路线如图 3 所示，包含四个核心模块：

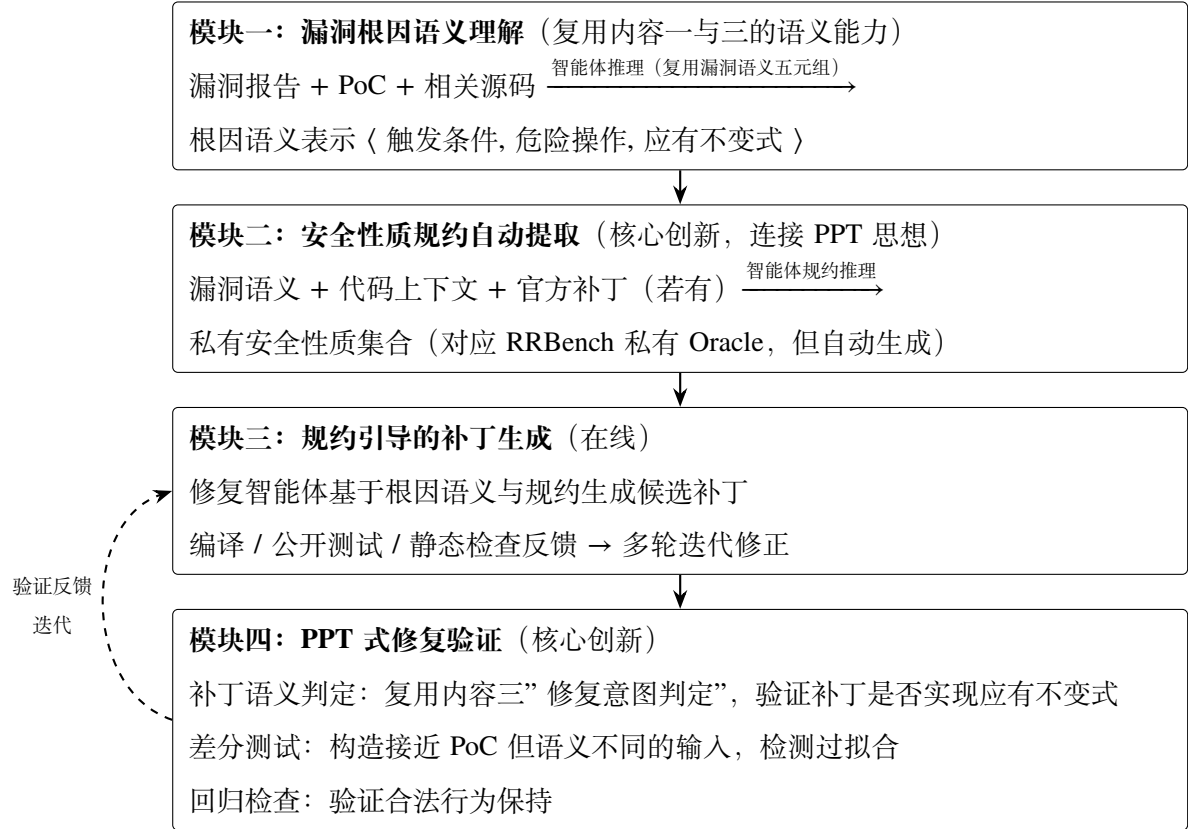


图 3 基于智能体的漏洞自动修复技术路线

- **模块一：漏洞根因语义理解。**依托统一的漏洞语义五元组表示（与研究内容三共享），将漏洞报告与 PoC 转化为结构化的根因语义表示，为后续修复提供深层理解基础。
- **模块二：安全性质规约自动提取。**这是连接 PPT 与修复的关键创新。借鉴 RRBench 私有 Oracle 的设计思想，但将其从”人工构造”扩展为”智能体自动生成”：智能体基于漏洞语义与代码上下文，自动提取补丁必须满足的安全性质集合。这些规约既可指导补丁生成，也可作为最终验证依据。

- **模块三：规约引导的补丁生成。**修复智能体在根因语义与安全规约的双重引导下生成候选补丁，并通过编译、公开测试与静态检查进行多轮迭代。
- **模块四：PPT 式修复验证。**这是本研究内容的核心创新，将 PPT 能力对偶迁移到修复验证：通过**补丁语义判定**（验证候选补丁是否真正实现应有不变式）、**差分测试**（自动构造与 PoC 语义相近但不同的输入以检测过拟合）、**回归检查**（验证合法功能保持）三重机制，系统性抑制过拟合补丁与合法功能回归。

可行性分析：（1）直接基于 RRBench：基准、评估框架、五款基线 agent 数据均已就绪，可快速开展对比实验，与课题组前期工作延续性强 [6]；（2）PPT 能力可迁移：研究内容三的”修复意图判定”与本内容的补丁验证需求本质同源，技术路线已形成闭环，风险分散；（3）规约自动提取有先例：ChatAFL 的协议规约提取、Firmalice 的特权模型等已证明 LLM 具备规约理解能力 [8, 28]；（4）工程基础成熟：SWE-agent [35]、OpenHands [36] 等开源框架提供了成熟的修复智能体底座。

实验方案：基准采用 RRBench 全部 115 个案例，后续扩展至 SEC-bench [34]、CVE-Bench [5] 子集；对比方法包括 SWE-agent [35]、OpenHands [36]、RepairAgent [37]、RustAgent、RustForger（即 RRBench 原五款）；评估指标包括 Correct Repair Rate（通过公开 + 私有验证）、Plausible-but-Private-Rejected Rate、平均迭代轮数、每例成本；消融实验分别验证安全规约引导、PPT 式验证与差分测试的独立贡献。预期 Correct Repair Rate $\geq 80\%$ ，私有拒绝率降低 $\geq 50\%$ ，在 14 个”无人能修”案例上成功修复 ≥ 4 个。

4.3 基于智能体的漏洞修复验证方法

拟解决的关键问题：智能体在端到端漏洞修复验证（以补丁存在性测试为核心任务）中的两大瓶颈——**剥离二进制中的补丁定位与演化补丁识别**。前期实证研究表明，前者占弱模型配置独有失败的 95.2%，后者是鲁棒性测试的主要失分点 [7]。两者本质上都源于跨抽象层次补丁语义对齐困难、修复意图难以形式化：源码级补丁意图与二进制级指令序列之间存在语义鸿沟，且现有方法过度依赖补丁的形式特征而非修复意图。

技术方案：针对上述问题，本文提出**语义先验引导的智能体修复验证增强框架**，整体技术路线如图 4 所示，包含三个核心模块：



图 4 基于智能体的漏洞修复验证技术路线

- **模块一：漏洞语义先验提取。**离线阶段利用智能体从 CVE 描述、补丁 diff 与源码上下文中提取漏洞语义五元组，作为统一语义先验，替代现有方法仅依赖原始补丁 diff 的浅层表示。
- **模块二：语义引导的补丁定位。**在线阶段采用”粗—细”两阶段定位：先用传统启发式（字符串、常量、导入表）快速缩小候选函数集，再将五元组作为约束注入智能体推理，引导其在候选函数中进行语义切片与置信度排序，输出 Top-K 补丁候选区域。
- **模块三：演化补丁的语义等价判定。**针对同一漏洞可能存在多种实现形式的修复（重构、拆分、合并等），不再追求”形式上的补丁匹配”，而是让智能体判断目标二进制中的干预点是否**实现了与原始补丁相同的修复意图**，并通过语义不变式进行交叉验证。

可行性分析：（1）数据基础充分：已构建 561 CVE 高保真基准与 12 组智能体配置的运行日志 [7, 63]，包含大量补丁定位与演化补丁的成功/失败案例，可

直接用于方法设计与消融验证；（2）技术路线有实证支撑：前期工作已证明“丰富补丁元数据提升 DSR”与“补丁定位是主要瓶颈”两个关键结论，本方案是这两个结论的直接延伸，技术风险低；（3）工具链成熟：智能体框架（Codex / MiniSWEAgent）、二进制分析工具（binutils / Ghidra）与评估基准均已就绪，可快速进入实验迭代。

实验方案：基准沿用前期 561-CVE Source-Built Benchmark + Patch Evolution Set + Ubuntu Packages Set；对比方法包括 Codex 原始配置、Lares [60]、PPTSP [61]、PS³ [51]、BinXray [47]；评估指标包括 DSR、Accuracy、补丁定位准确率、每例 token 成本与时延；消融实验分别验证三个模块的独立贡献。预期全配置 DSR ≥ 0.98 ，演化补丁子集 DSR 提升 $\geq 15\%$ ，成本增加 $\leq 10\%$ ；进一步将验证能力对偶迁移至修复场景，在 RRBench 生成补丁上验证修复正确性判定的有效性。

4.4 实验方案设计

4.4.1 整体评估策略

三个研究内容的实验遵循统一策略：

1. **基准优先：**每个内容均基于已有或新建的高质量基准，确保可复现与可比较。
2. **多维度评估：**从效果（准确率/发现数/修复率）、效率（时间/token 成本）、鲁棒性（跨配置/跨场景）三个维度综合评估。
3. **消融驱动：**每个核心模块均设计消融实验，验证其独立贡献。
4. **跨内容联动：**设计端到端实验，验证三个内容构成的闭环是否产生协同增益。

4.4.2 端到端闭环验证实验

为验证三个研究内容构成的攻防闭环的有效性，设计如下端到端实验：

1. **输入：**一批含已知漏洞的 IoT 固件镜像（部分为真实 CVE，部分为人工植入）。

2. **流程**：内容一挖掘未知语义漏洞，产出根因与 PoC；内容二对确认的漏洞进行自动修复，产出候选补丁；内容三对修复后固件进行 PPT 式修复验证，判定补丁是否真正消除漏洞根因；同时内容三对固件中已知 CVE 的修复状态进行补丁存在性核查，覆盖供应链审计场景。
3. **评估**：闭环整体准确率、各环节能力复用带来的效率提升、相比独立运行的性能差异。

4.4.3 基准建设计划

表 2 基准建设计划

基准	状态	规模	用途
561-CVE PPT 基准	已建成	561 CVE / 10 项目	内容三
语义漏洞固件基准	拟建设	10-15 真实固件 + 50 合成案例	内容一
RRBench	已建成 (课题组)	115 案例 / 95 仓库	内容二
端到端闭环基准	拟整合	复用上述 + 新增修复验证	闭环验证

4.4.4 风险与应对

表 3 风险与应对策略

风险	影响	应对策略
语义 oracle 自动构造准确率不足	内容一假阳性率高	引入人工审核接口；采用多智能体交叉验证
自因变量建模在复杂固件上扩展性差	内容一覆盖率不达预期	从中小型固件起步逐步扩展；结合动态污点辅助识别
修复验证的私有规约生成不完整	内容二私有拒绝率下降有限	结合官方补丁对比学习；引入形式化方法辅助规约补全
智能体推理成本过高	方法难以规模化	分级模型策略（轻量粗筛 + 重量精判）；缓存中间语义表示

五 已有科研基础与所需的科研条件

5.1 已有科研基础

本人已经针对本文涉及的相关研究进行了充分调研和分析，积累了相应理论和实践基础。

针对研究内容一（基于智能体的语义漏洞挖掘），本人正在开展相关调研与原型设计工作。

针对研究内容二（基于智能体的漏洞自动修复），本人深度参与课题组 RRBench 基准的讨论与分析工作，熟悉其两阶段评估设计与五款基线智能体的运行数据 [6]，为后续修复研究奠定了直接基础。

针对研究内容三（基于智能体的漏洞修复验证），本人已完成两项相互衔接的实证研究：（1）构建了包含 561 个 CVE、覆盖 10 个广泛使用开源项目的高保真 PPT 基准，对五款代表性工具进行了系统评估，揭示了“高准确率、低决策成功率”的普遍现象，并提出改进策略取得显著提升，成果发表于 ISSTA 2026 [63]；（2）系统评估了编码智能体在端到端 PPT 任务中的能力边界与配置空间，识别出补丁定位与演化补丁识别两大瓶颈，成果已完成论文撰写 [7]。

（待补充：项目参与情况、其他安全分析实践成果。）

5.2 所需科研条件

（待撰写：计算资源（GPU 集群与 LLM API 预算）、数据资源（固件语料、CVE 数据库）、团队与项目支撑。）

六 研究工作计划与进度安排

1. **2026.09 – 2027.03**：完成研究内容一。构建自因变量统一建模与语义 oracle 自动构造方法，实现多智能体语义漏洞挖掘原型，建设固件语义漏洞基准，撰写并发表研究内容一论文。
2. **2027.03 – 2027.12**：完成研究内容二。实现规约引导的智能体漏洞修复框架，在 RRBench 上完成系统评估，撰写并发表研究内容二论文。
3. **2028.01 – 2028.10**：完成研究内容三。设计并实现语义先验引导的智能体修

复验证（PPT 增强）框架，在 561-CVE 基准上完成对比与消融实验，撰写并发表研究内容三论文。

4. **2028.10 – 2029.06**：完成三个研究内容的端到端闭环集成与验证，整理成果，撰写博士学位论文，准备答辩。

（注：以上时间节点为初步规划，可按实际学制与导师意见调整。）

参考文献

- [1] Apache Software Foundation. Apache Log4j CVE-2021-44228 [EB/OL]. 2021. <https://nvd.nist.gov/vuln/detail/CVE-2021-44228>.
- [2] Google Project Zero and DeepMind. From naptime to big sleep: Using large language models to catch vulnerabilities in real-world code [EB/OL]. 2024. <https://googleprojectzero.blogspot.com/2024/10/from-naptime-to-big-sleep.html>.
- [3] DARPA. AI cyber challenge (AIxCC) [EB/OL]. 2025. <https://aicyberchallenge.com/>.
- [4] Jimenez C E, Yang J, Wettig A, et al. SWE-bench: Can language models resolve real-world GitHub issues? [C]//International Conference on Learning Representations (ICLR). 2024.
- [5] Anonymous. CVE-Bench: A benchmark for AI agents' ability to exploit real-world web application vulnerabilities [Z]. 2024.
- [6] Anonymous. RRBench: A repository-level benchmark for agentic repair of real-world Rust vulnerabilities [Z]. 2026.
- [7] Zhang X, et al. Understanding coding agents for patch presence testing [Z]. 2026.
- [8] Shoshitaishvili Y, Wang R, Hauser C, et al. Fomalice: Automatic detection of authentication bypass vulnerabilities in binary firmware [C]//Network and Distributed System Security Symposium (NDSS). 2015.
- [9] Davidson D, Moench B, Ristenpart T, et al. FIE on firmware: Finding vulnerabilities in embedded systems using symbolic execution [C]//22nd USENIX Security Symposium. 2013: 463-478.
- [10] Redini N, Machiry A, Wang R, et al. Karonte: Detecting insecure multi-binary interactions in embedded firmware [C]//2020 IEEE Symposium on Security and Privacy. 2020: 1544-1561.
- [11] Wu M, et al. Operation mango: Scalable discovery of taint-style vulnerabilities in binary firmware services [M]//33rd USENIX Security Symposium. 2024.
- [12] Anonymous. FIRE: Combining refuzzing with IoT firmware [M]//33rd USENIX Security Symposium. 2024.

- [13] Anonymous. OctopusTaint: Scalable cross-binary taint analysis for firmware [M]//Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security. 2024.
- [14] Anonymous. UVScan: Detecting third-party component usage violations in IoT firmware [M]//32nd USENIX Security Symposium. 2023.
- [15] Liu P, Sun C, Zheng Y, et al. Harnessing the power of LLM to support binary taint analysis [J]. arXiv preprint arXiv:2310.08275, 2025.
- [16] Zheng Y, Davanian A, Yin H, et al. FIRM-AFL: High-throughput greybox fuzzing of IoT firmware via augmented process emulation [C]//28th USENIX Security Symposium. 2019: 1099-1114.
- [17] Feng B, Mera A, Lu L. P2IM: Scalable and hardware-independent firmware testing via automatic peripheral interface modeling [C]//29th USENIX Security Symposium. 2020: 1237-1254.
- [18] Cao C, Guan L, Ming J, et al. Device-agnostic firmware execution is possible: A concolic execution approach for peripheral emulation [C]//Annual Computer Security Applications Conference (ACSAC). 2020.
- [19] Scharnowski T, Bars N, Schloegel M, et al. Fuzzware: Using precise MMIO modeling for effective firmware fuzzing [C]//31st USENIX Security Symposium. 2022: 1239-1256.
- [20] Anonymous. Ember-IO: Effective firmware fuzzing with realistic peripheral interrupts [Z]. 2023.
- [21] Anonymous. Firmvenom: Peripheral-semantics-aware firmware fuzzing [Z]. 2024.
- [22] Pham V T, Böhme M, Roychoudhury A. AFLNet: A greybox fuzzer for network protocols [C]//2020 IEEE 13th International Conference on Software Testing, Validation and Verification (ICST). 2020: 460-465.
- [23] Natella R. StateAFL: Greybox fuzzing for stateful network servers [C]//2022 52nd Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN). 2022.
- [24] Wang D, et al. SyzTrust: State-aware fuzzing on trusted OS designed for IoT devices [M]//2024 IEEE Symposium on Security and Privacy. 2024.
- [25] Anonymous. CONFU: Configuration fuzzing for software [Z]. 2023.
- [26] Ji J, Zhang C, Gan S, et al. FirmAgent: Leveraging fuzzing to assist LLM agents with IoT firmware vulnerability discovery [C/OL]//Network and Distributed System Security Symposium (NDSS). 2026. DOI: [10.14722/ndss.2026.231943](https://doi.org/10.14722/ndss.2026.231943).
- [27] Anonymous. FirmPilot: Multi-agent firmware rehosting with LLM [Z]. 2025.
- [28] Meng R, Mirchev M, Böhme M, et al. Large language model guided protocol fuzzing [C]//Network and Distributed System Security Symposium (NDSS). 2024.

- [29] Liu Y, Liu Z, Yu Z, et al. Towards generality: Task-adaptive binary analysis via semantic retrieval and verifiable reasoning [C]//35th USENIX Security Symposium. 2026.
- [30] Le Goues C, Nguyen T, Forrest S, et al. GenProg: A generic method for automatic software repair [J]. IEEE Transactions on Software Engineering, 2012, 38(1): 54-72.
- [31] Long F, Rinard M. Staged program repair with condition synthesis [C]//Proceedings of the 2015 10th Joint Meeting on Foundations of Software Engineering. 2015: 166-178.
- [32] Long F, Rinard M. Automatic patch generation by learning correct code [C]//Proceedings of the 43rd Annual ACM SIGPLAN-SIGACT Symposium on Principles of Programming Languages. 2016: 298-312.
- [33] Wen M, Chen J, Wu R, et al. Context-aware patch generation for better automated program repair [C]//Proceedings of the 40th International Conference on Software Engineering. 2018: 1-11.
- [34] Anonymous. SEC-bench: Automated benchmarking of LLM agents on real-world software security tasks [Z]. 2025.
- [35] Yang J, Jimenez C E, Wettig A, et al. SWE-agent: Agent-computer interfaces enable automated software engineering [C]//Advances in Neural Information Processing Systems: volume 37. 2024: 50528-50652.
- [36] Wang X, Li B, Song Y, et al. OpenHands: An open platform for AI software developers as generalist agents [EB/OL]. 2024. DOI: [10.48550/arXiv.2407.16741](https://doi.org/10.48550/arXiv.2407.16741).
- [37] Bouzenia I, Devanbu P, Pradel M. RepairAgent: An autonomous, LLM-based agent for program repair [C]//Proceedings of the IEEE/ACM 47th International Conference on Software Engineering. 2025.
- [38] Anonymous. RUSPATCH: Dynamic patching for Rust [Z]. 2024.
- [39] Anonymous. AkiraRust: Semantic repair of undefined behavior in Rust [Z]. 2025.
- [40] Hu Y, Li Z, Shu K, et al. Sok: Automated vulnerability repair: Methods, tools, and assessments [C]//34th USENIX Security Symposium. 2025: 4421-4440.
- [41] Yu Z, Guo Z, Wu Y, et al. PatchAgent: A practical program repair agent mimicking human expertise [C]//34th USENIX Security Symposium. 2025: 4381-4400.
- [42] Li F, Paxson V. A large-scale empirical study of security patches [C/OL]//Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security. 2017: 2201-2215. DOI: [10.1145/3133956.3134072](https://doi.org/10.1145/3133956.3134072).
- [43] Machiry A, Redini N, Camellini E, et al. SPIDER: Enabling fast patch propagation in related software repositories [C/OL]//2020 IEEE Symposium on Security and Privacy. 2020: 1562-1579. DOI: [10.1109/SP40000.2020.00038](https://doi.org/10.1109/SP40000.2020.00038).

- [44] Zhang Z, Zhang H, Qian Z, et al. An investigation of the Android kernel patch ecosystem [C]// 30th USENIX Security Symposium. 2021: 3649-3666.
- [45] Red Hat. Security backporting practice [EB/OL]. 2026. <https://access.redhat.com/security/updates/backporting>.
- [46] Zhang H, Qian Z. Precise and accurate patch presence test for binaries [C]//27th USENIX Security Symposium. 2018: 887-902.
- [47] Xu Y, Xu Z, Chen B, et al. Patch based vulnerability matching for binary programs [C/OL]// Proceedings of the 29th ACM SIGSOFT International Symposium on Software Testing and Analysis. 2020: 376-387. DOI: [10.1145/3395363.3397361](https://doi.org/10.1145/3395363.3397361).
- [48] Xu X, Zheng Q, Yan Z, et al. PatchDiscovery: Patch presence test for identifying binary vulnerabilities based on key basic blocks [J/OL]. IEEE Transactions on Software Engineering, 2023, 49(12): 5279-5294. DOI: [10.1109/TSE.2023.3332732](https://doi.org/10.1109/TSE.2023.3332732).
- [49] Jiang Z, Zhang Y, Xu J, et al. PDiff: Semantic-based patch presence testing for downstream kernels [C/OL]//Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security. 2020: 1149-1163. DOI: [10.1145/3372297.3417240](https://doi.org/10.1145/3372297.3417240).
- [50] Yang S, Xu Z, Xiao Y, et al. Towards practical binary code similarity detection: Vulnerability verification via patch semantic analysis [J/OL]. ACM Transactions on Software Engineering and Methodology, 2023, 32(6): 1-29. DOI: [10.1145/3604608](https://doi.org/10.1145/3604608).
- [51] Zhan Q, Hu X, Li Z, et al. PS³: Precise patch presence test based on semantic symbolic signature [C/OL]//Proceedings of the IEEE/ACM 46th International Conference on Software Engineering. 2024: 1-12. DOI: [10.1145/3597503.3639134](https://doi.org/10.1145/3597503.3639134).
- [52] Zhan Q, Hu X, Xia X, et al. REACT: IR-level patch presence test for binary [C/OL]// Proceedings of the 39th IEEE/ACM International Conference on Automated Software Engineering. 2024: 381-392. DOI: [10.1145/3691620.3695012](https://doi.org/10.1145/3691620.3695012).
- [53] Dai J, Zhang Y, Jiang Z, et al. BScout: Direct whole patch presence test for Java executables [C]//29th USENIX Security Symposium. 2020: 1147-1164.
- [54] Pan Z, Hu X, Xia X, et al. PPT4J: Patch presence test for Java binaries [C/OL]//Proceedings of the IEEE/ACM 46th International Conference on Software Engineering. 2024: 1-12. DOI: [10.1145/3597503.3639231](https://doi.org/10.1145/3597503.3639231).
- [55] Xie Z, Wen M, Jia H, et al. Precise and efficient patch presence test for Android applications against code obfuscation [C/OL]//Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis. 2023: 347-359. DOI: [10.1145/3597926.3598061](https://doi.org/10.1145/3597926.3598061).
- [56] Xie Z, Wen M, Wei Z, et al. Unveiling the characteristics and impact of security patch evolution [C/OL]//Proceedings of the 39th IEEE/ACM International Conference on Automated Software Engineering. 2024: 1094-1106. DOI: [10.1145/3691620.3695488](https://doi.org/10.1145/3691620.3695488).

- [57] Hu P, Liang R, Chen K. DeGPT: Optimizing decompiler output with LLM [C/OL]//Network and Distributed System Security Symposium (NDSS). 2024. DOI: [10.14722/ndss.2024.24401](https://doi.org/10.14722/ndss.2024.24401).
- [58] Tan H, Luo Q, Li J, et al. LLM4Decompile: Decompiling binary code with large language models [C/OL]//Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing. 2024: 3473-3487. DOI: [10.18653/v1/2024.emnlp-main.203](https://doi.org/10.18653/v1/2024.emnlp-main.203).
- [59] Xie D, Zhang Z, Jiang N, et al. ReSym: Harnessing LLMs to recover variable and data structure symbols from stripped binaries [C/OL]//Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security. 2024: 4554-4568. DOI: [10.1145/3658644.3670340](https://doi.org/10.1145/3658644.3670340).
- [60] Li S, Zheng Y, Li H, et al. Lares: LLM-driven code slice semantic search for patch presence testing [C/OL]//2025 40th IEEE/ACM International Conference on Automated Software Engineering. 2025: 919-931. DOI: [10.1109/ASE63991.2025.00081](https://doi.org/10.1109/ASE63991.2025.00081).
- [61] Xu C, Luo S, Duan X, et al. PPTSP: Patch presence test via semantic normalization and key path extraction [J/OL]. Software Quality Journal, 2026, 34(2). DOI: [10.1007/s11219-026-09760-9](https://doi.org/10.1007/s11219-026-09760-9).
- [62] Kapoor S, Stroebl B, Siegel Z S, et al. AI agents that matter [EB/OL]. 2024. DOI: [10.48550/arXiv.2407.01502](https://doi.org/10.48550/arXiv.2407.01502).
- [63] Zhang X, Zheng Y, Luo W, et al. A comprehensive empirical analysis of patch presence testing: Capabilities, limitations, and paths forward [J/OL]. Proceedings of the ACM on Software Engineering, 2026, 3(ISSTA): ISSTA053. DOI: [10.1145/3832144](https://doi.org/10.1145/3832144).